Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Project details

Title: Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

AL-Enhanced User Protection (AIP)

AI-Enhanced User Protection (AIUP) is an advanced security approach that utilizes artificial intelligence and machine learning to authenticate user identities and safeguard digital platforms against cyber threats. Unlike conventional security mechanisms that depend on fixed credentials such as passwords or even two-factor authentication (2FA), AIUP continuously studies user behavior to generate a dynamic and evolving trust score for everyone.

AIUP plays an important role in modern cybersecurity because it overcomes the shortcomings of traditional perimeter-based defenses. As cyberattacks become more sophisticated—often involving stolen credentials, phishing attempts, and social engineering—relying solely on “what you know” (passwords) or “what you have” (tokens) is no longer adequate. AIUP introduces a third layer of protection based on behavioral identity, focusing on how a user interacts with systems. By continuously monitoring user activity, organizations can prevent account compromise, reduce fraudulent actions, and confirm that the user interacting with the system remains authentic throughout the session.

Abstract:
Traditional VPN architecture struggles to effectively address contemporary cybersecurity threats such as lateral movement within networks and excessive network privileges. These limitations highlight the need to adopt Zero Trust security principles. This project presents the detailed design, implementation, and management of a Zero Trust Network Access (ZTNA) solution using Zscaler Private Access (ZPA) within a large institutional environment. The main goal of this project is to replace traditional network-level access with application-specific, identity-based connectivity. Zscaler App Connectors are deployed within the institutional data center, while the platform is integrated with existing identity providers such as Azure AD and endpoint security tools. Through this architecture, every user-to-application connection is routed through a cloud-native broker, ensuring secure access. This approach makes internal applications effectively invisible to the public internet, thereby removing potential attack surfaces. The project also examines the integration of Zscaler with other security ecosystems, including SIEM platforms such as QRadar for centralized logging and MISP for consuming threat intelligence feeds that support adaptive access policies. The implemented framework results in a scalable and resilient security architecture that enforces least-privilege access, provides detailed auditing capabilities, and significantly strengthens the institution’s overall cybersecurity posture.

Use Case Scenarios:

Scenario 1: Secure Access to Research Repository for Faculty
A faculty member working from an off-campus location needs to access the university's internal research repository to upload project documents. Using Zscaler Private Access (ZPA), the faculty member requests access to the repository application. The system verifies the user's identity through the integrated identity provider and checks whether the device meets security compliance requirements before allowing the connection.

Output

- User identity authenticated through the identity provider
- Device security posture validated (antivirus enabled and system updated)
- Encrypted micro-tunnel established specifically to the research repository
- No direct visibility of the internal network for the user

Scenario 2: Temporary Access for Visiting Professor
A visiting professor collaborating on a short-term research project requires access to a specific internal analytics application. The IT administrator creates a policy in Zscaler that allows access only to the designated application and only for the duration of the collaboration.

Output:

- Visiting professor authenticated using assigned credentials
- Access restricted to the analytics application only
- Policy configured with a predefined expiration date
- Application remains hidden from external internet scanning

Scenario 3: Secure Access to Internal Library System for Students
Students accessing the university's digital library system from different locations must authenticate through the Zscaler environment. Once authenticated, the ZTNA platform establishes a secure connection between the student's device and the library application without exposing other internal systems.

Output

- Student authentication verified using institutional credentials
- Secure connection created exclusively to the library system
- Other internal resources remain inaccessible
- System capable of handling high concurrent student traffic

Scenario 4: Remote Troubleshooting by IT Support Team
An IT support engineer needs to remotely diagnose an issue in an internal application server. Instead of connecting through a full network VPN, the engineer uses ZPA to connect directly to the server management interface required for troubleshooting.

Output:

- Engineer identity verified through multi-factor authentication
- Direct secure connection established to the target server interface
- Administrative session monitored and logged
- Unauthorized access attempts to other systems automatically denied

Scenario 5: Secure Vendor Access for Software Maintenance
A third-party software vendor needs limited access to update a specific internal application hosted within the university infrastructure. The administrator configures an access rule allowing the vendor to connect only to that application through ZPA.

Output

- Vendor identity validated through external authentication integration
- Access granted only to the designated maintenance application
- Activity logs recorded for auditing and compliance
- Access revoked automatically after maintenance completion

STAGE 1:

Title of the project: -

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview: -

This project focuses on creating an AI-driven identity verification system aimed at enhancing digital security by analyzing and validating user identities through behavioral activity on online platforms. The system applies advanced machine learning techniques to construct comprehensive user profiles, enabling it to distinguish legitimate user activity from potentially suspicious behavior. It addresses major cybersecurity concerns such as unauthorized access, fraudulent activities, and various digital threats encountered across online services.
The primary objective of the system is to strengthen online security by carefully evaluating and authenticating user identities based on their behavioral data. To accomplish this, the platform utilizes advanced technologies such as deep learning, neural networks, and natural language processing to develop adaptive behavioral profiles for each user. These profiles continuously update and evolve as users interact with digital platforms over time.

One of the major capabilities of the system is real-time anomaly detection, which enables the identification of unusual behavior that deviates from a user's typical activity patterns. When such irregular behavior is detected, the system can immediately respond to reduce potential security risks. This mechanism helps prevent unauthorized access and ensures safer user interactions.
To further reinforce the security structure, the system integrates multi-factor authentication (MFA) mechanisms. Whenever suspicious activity is identified, additional verification procedures are triggered to confirm the user's identity. At the same time, notifications are sent to both users and administrators, enabling prompt responses to potential threats.

Another critical component of the system is secure data storage and management. Sensitive data such as behavioral profiles and anomaly detection logs are stored using protected mechanisms to ensure privacy and maintain data integrity.
The system also incorporates an integration layer that allows seamless interaction with multiple online platforms and services. Monitoring and reporting features are included to evaluate system performance and track security status, promoting transparency and accountability.
To support large-scale usage, the platform is designed with scalability and load-balancing capabilities. Strong encryption is implemented for data both in transit and at rest, and additional security mechanisms such as firewalls and intrusion detection systems are used to maintain compliance with established data protection standards.
Furthermore, the system can optionally be deployed on cloud infrastructure, providing improved flexibility and scalability. Continuous training and optimization of machine learning models ensure that the platform adapts to evolving cyber threats and changing user behavior. Deploying system components across multiple geographic locations can also enhance redundancy, reliability, and performance.

List of teammates–

S.no	Name	College	Contact
1	M. ATHI SESHAN	Kumaraguru College of Liberal Arts and Science	athiseshan.23bds@kclas.ac.in
2	MAHALAKSHMI M.	Kumaraguru College of Liberal Arts and Science	mahalakshmi.23bds@kclas.ac.in
3	NITHISH R.	Kumaraguru College of Liberal Arts and Science	nithishr2005@gmail.com
4	P. DEVADARSHINI	Kumaraguru College of Liberal Arts and Science	devadarshini027@gmail.com
5	ANAMIKA M.	Kumaraguru College of Liberal Arts and Science	anamika.23bds@kclas.ac.in

List of Vulnerability Table-

S.no	Vulnerability Name	CWE/CVE - No
1	Improper Sanitization of File Paths	CWE- 284: Improper Access Control
2	Invalid Certificate	CWE-395: Improper Certificate Validation
3	Missing X-Frame-Options Header	CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames
4	X-Content-Type Options Header Missing	CWE -918: Server-Side Request Forgery (SSRF)
5	Drupal Ajax API shows JSONP not disabled by default	CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities
6	Drupal Api Vulnerability	CWE-20: Improper Input Validation

7	Improper API Filtration	CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
8	Denial of Service	CWE -400: Uncontrolled Resource Consumption
9	TLS Version 1.0 Protocol Detection	CWE-327: Use of a Broken or Risky Cryptographic Algorithm
10	web.config File Information Disclosure	CWE-497: Exposure of Sensitive System Information to an Unauthorized Control Sphere

Main Website:

S.no	Vulnerability Name	CWE - No
1	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
2	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralization of Input During Web Page Generation
3	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

REPORT: -

Practice Website: http://www.itsecgames.com/

1) Vulnerability Name: Improper Sanitization of File Paths

CWE- 284: Improper Access Control

OWASP Category: A01:2021-Broken Access Control

Description: The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact: This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after applying a security release.

Steps to Reproduce: https://www.shodan.io/host/31.3.96.40

CVE-2023-31250	The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Recommendation:

1. **Apply Security Updates**: The primary recommendation is to apply the security update provided by Drupal as soon as it becomes available. Security updates typically include fixes for known vulnerabilities like this one.

2. **Review Configuration**: After applying the update, review your Drupal site's configuration to ensure that private files remain protected as intended. Make any necessary adjustments to your site's file permissions or access controls.

3. **Regular Audits**: Conduct regular security audits and vulnerability assessments to identify and address potential security issues in your Drupal site.

4. **Access Control**: Implement strong access controls to ensure that only authorized users can access private files. Review and restrict file access permissions as needed.

5. **Data Minimization**: Minimize the amount of sensitive data stored on your Drupal site. Only store data that is necessary for your site's functionality.

2) Vulnerability Name: Invalid Certificate

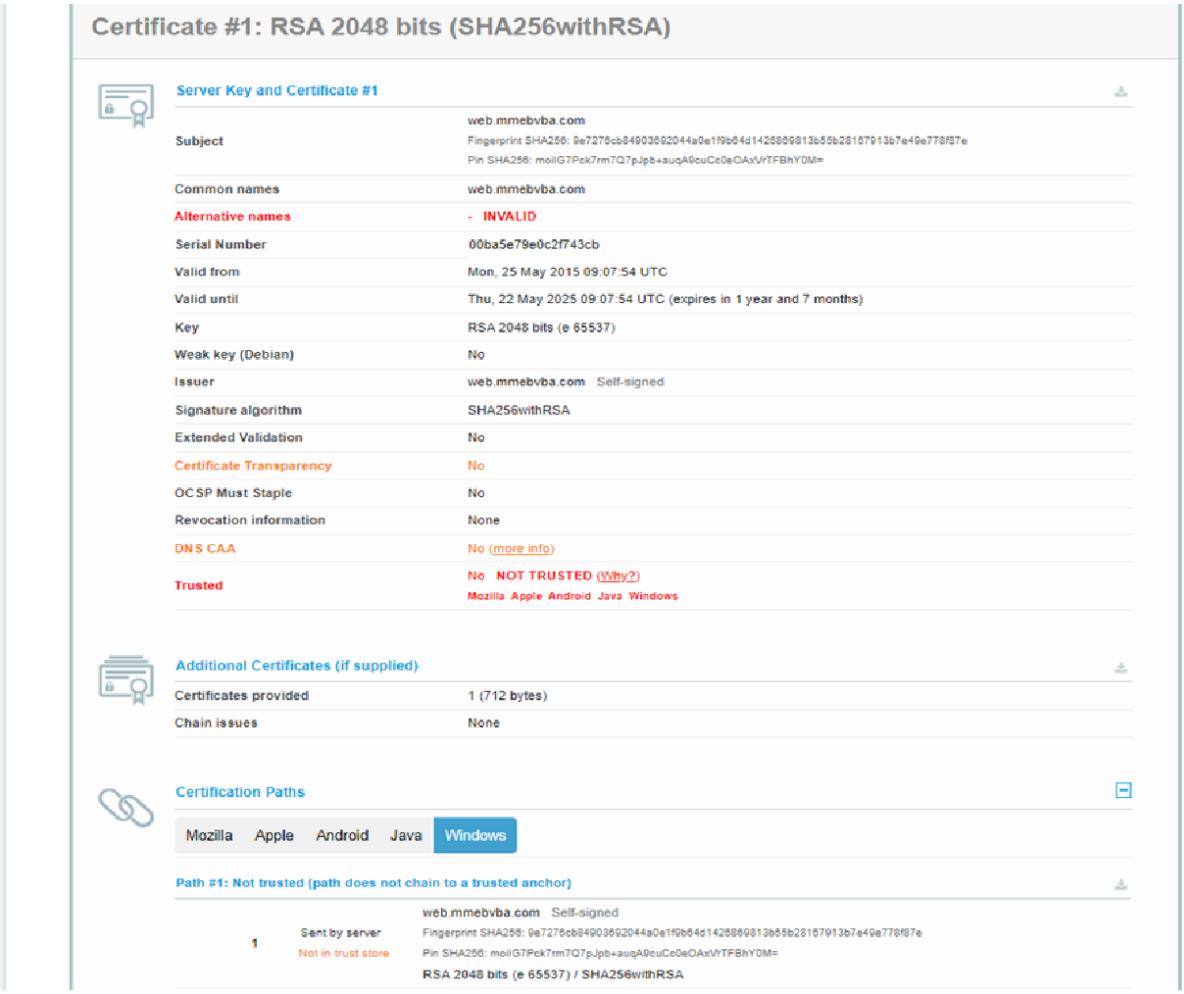
CWE-395: Improper Certificate Validation

OWASP Category: A07:2021 – Identification and Authentication Failures

Description: When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact: Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches),Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware)

Steps to Reproduce: https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28167913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+auqA9cuCc0eOAxVrTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28167913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+auqA9cuCc0eOAxVrTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA

Recommendation:

1. **Use trusted certificate authorities:** Only trust digital certificates issued by well-known and trusted certificate authorities.

2. **Verify certificate chains:** Verify that the certificate presented by the remote party is valid and issued by a trusted certificate authority. Verify the entire certificate chain, including intermediate certificates.

3. **Check certificate revocation status:** Check the revocation status of the certificate presented by the remote party to ensure that it has not been revoked.

4. **Use certificate pinning:** Implement certificate pinning to ensure that the communication only occurs with the exact certificate or certificate authority specified.

5. **Keep software up to date:** Keep software and security protocols up to date, as new vulnerabilities and security patches are regularly released.

3) Vulnerability Name: Missing X-Frame-Options Header

CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames

OWASP Category: A04:2021-Insecure Design

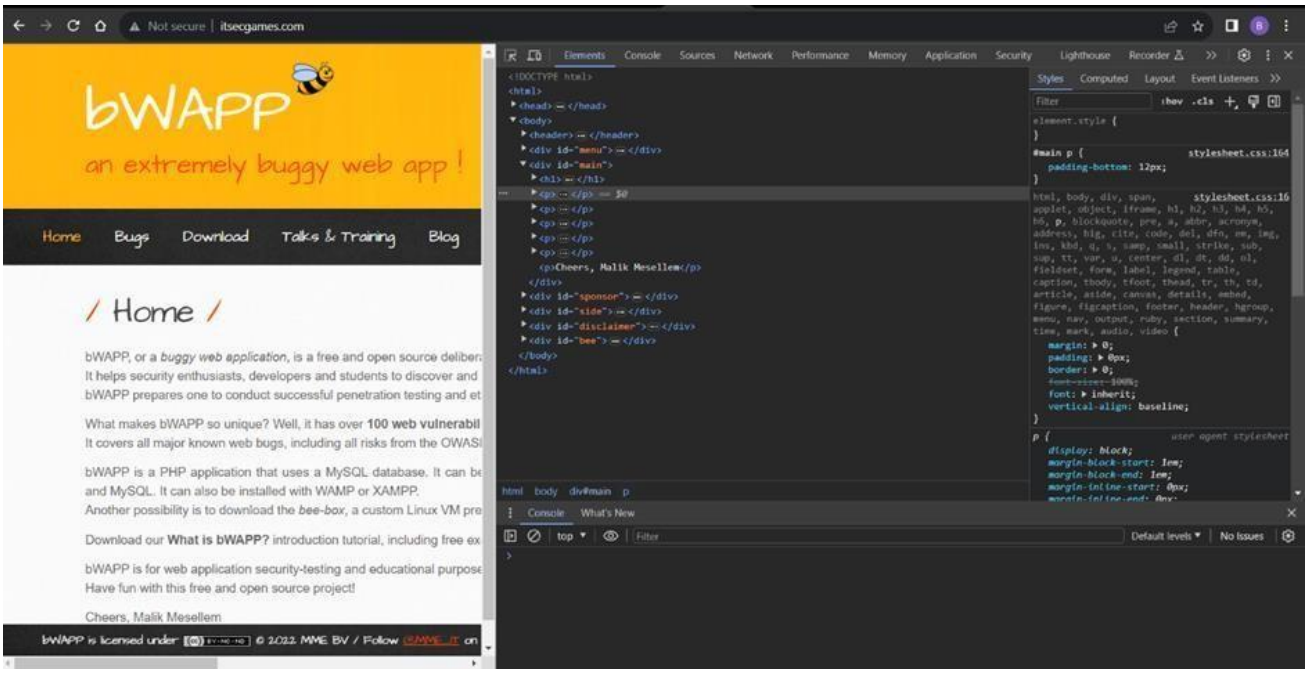
Description: A web application is expected to place restrictions on whether it is allowed to be rendered within frames, iframes, objects, embed or applet elements. Without the restrictions, users can be tricked into interacting with the application when they are not intending to.

Business Impact: This enables path to the attackers to manipulate or gain unauthorized access to user interface elements, potentially leading to deceptive or malicious user interactions. This can result in data leakage, fraud, user distrust, and reputational damage, undermining the integrity and trustworthiness of the application and causing financial losses.

Vulnerability Path: http://www.itsecgames.com/

Steps to Reproduce:

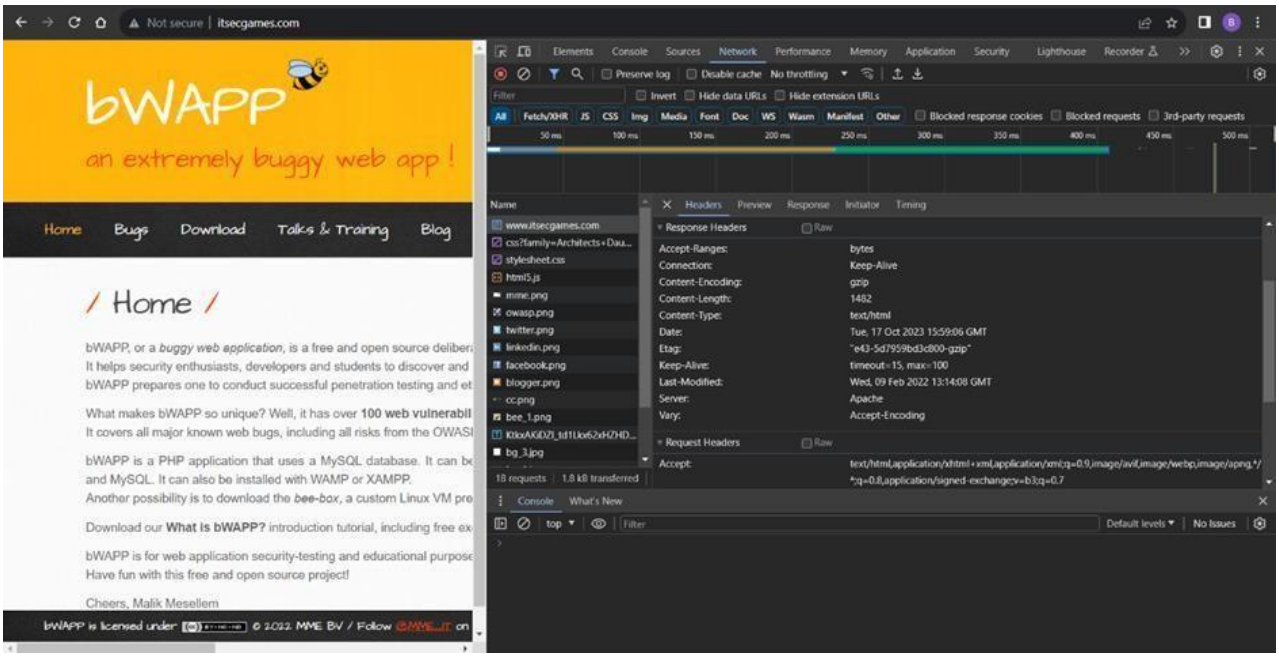
1. Open the practice website to inspect



2. Go to network and start capturing using F5 or Ctrl+R

3. Go to html document and see if x-frame-options present in response headers or not

4. If not the absence of this header indicates that the website may not have protection against embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.



Recommendation:

1. **Implement Proper UI Layer Access Controls:** Enforce access controls to restrict access to UI layers or frames based on user privileges.

2. **Use Session and Authentication Management:** Ensure robust session management and user authentication mechanisms to prevent unauthorized access.

3. **Implement Content Security Policies (CSP):** Use CSP headers to control where resources can be loaded from and mitigate against frame-based attacks.

4. **Keep Software and Libraries Updated:** Stay current with software updates and patches to address known security issues.

4) Vulnerability Name: X-Content-Type Options Header Missing

CWE -918: Server-Side Request Forgery (SSRF)

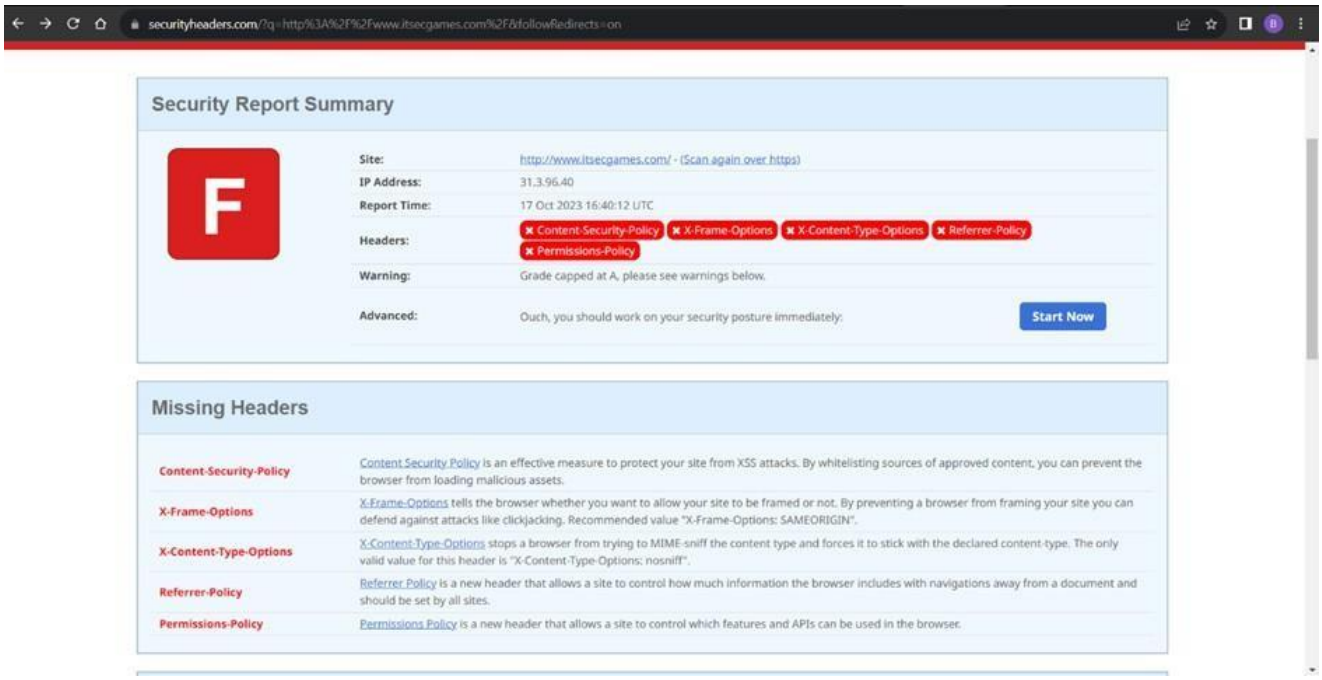
OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path :
https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects=on

Steps to Reproduce:




```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ nikto -h http://www.itsecgames.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          31.3.96.40
+ Target Hostname:    www.itsecgames.com
+ Target Port:        80
+ Start Time:         2023-10-17 09:03:40 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.
org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-
vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /com.tgz: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/proje
ct/remove_http_headers
+ /com.tgz: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31
.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800,
 mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce
ss-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:           2023-10-17 09:29:14 (GMT5.5) (1534 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.

- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.
- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

5) Vulnerability Name: Drupal Ajax API shows JSONP not disabled by default

CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

OWASP Category: A06:2021-Vulnerable and Outdated Components

Description: Vulnerable and outdated components refer to using software libraries, modules, or dependencies within a web application that have known security issues or are not updated to the latest secure versions. This can include plugins, frameworks, or APIs that are no longer maintained or have publicly documented vulnerabilities.

Business Impact: The presence of vulnerable and outdated components in a web application poses significant security risks. Attackers can exploit these weaknesses to gain unauthorized access, inject malicious code, steal sensitive data, or disrupt the system's operation. The potential business impacts include compromised user data, damaged reputation, legal consequences, and financial losses due to breach recovery and remediation efforts.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2020-13666	4.3 Cross-site scripting vulnerability in Drupal Core. Drupal AJAX API does not disable JSONP by default, allowing for an XSS attack. This issue affects: Drupal Drupal Core 7.x versions prior to 7.73; 8.8.x versions prior to 8.8.10; 8.9.x versions prior to 8.9.6; 9.0.x versions prior to 9.0.6.

Recommendation:

1. **Regular Updates:** Keep all components, libraries, and dependencies up to date by applying security patches and upgrades.

2. **Vulnerability Scanning:** Conduct periodic vulnerability assessments to identify and address potential issues.

3. **Dependency Management:** Implement a strategy for managing third-party dependencies, including continuous monitoring of their security status.

4. **Security Testing:** Perform regular security testing, including penetration testing and code review, to identify and remediate vulnerabilities.

5. **Change Control:** Maintain a change management process to assess the impact of new components and ensure they don't introduce new vulnerabilities.

6) Vulnerability Name: Drupal Api Vulnerability

CWE-20: Improper Input Validation

OWASP Category: A03:2021 – Injection

Description: The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Business Impact: The impact of a successful SQL injection attack can be devastating for businesses. It can result in unauthorized access to sensitive information, data theft, financial losses, damage to reputation, and legal consequences. Depending on the nature of the application and data involved, SQL injection can lead to compliance violations, customer trust erosion, and operational disruption.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2022-25271	4.3 Drupal core's form API has a vulnerability where certain contributed or custom modules' forms may be vulnerable to improper input validation. This could allow an attacker to inject disallowed values or overwrite data. Affected forms are uncommon, but in certain cases an attacker could alter critical or sensitive data.

Recommendation:

1. **Input Validation:** Implement rigorous input validation on all user inputs and ensure that only safe, sanitized data is passed to the database.

2. **Parameterized Queries:** Use parameterized queries or prepared statements to separate SQL code from user input, preventing malicious injections.

3. **Escaping User Input:** If parameterized queries are not feasible, escape user input before incorporating them into SQL queries to neutralize special characters.

4. **Least Privilege Principle:** Limit the permissions and access rights of database accounts to the minimum required for specific tasks to minimize the potential damage of an attack.

5. **Web Application Firewalls (WAF):** Employ WAFs to filter and block malicious SQL injection attempts.

6. **Regular Security Testing:** Conduct regular security assessments, including penetration testing, to identify and address vulnerabilities.

7) Vulnerability Name: Improper API Filtration

CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

OWASP Category: A07-2017: Cross-site Scripting (XSS)

Description: The product does not neutralize or incorrectly neutralizes user-controllable input before it is placed in output that is used as a web page that is served to other users.

Business Impact: If exploited, this vulnerability allows attackers to inject malicious scripts into web pages, which can be viewed by other users. The potential business impacts include data theft, unauthorized access, compromised user accounts, damaged reputation, and financial losses. Attackers can use XSS to steal sensitive information, such as user credentials, personal data, or financial details, leading to regulatory compliance violations and legal liabilities. Additionally, defacement or manipulation of website content can erode customer trust and result in lost revenue.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Steps to Reproduce:

CVE-2020-13672	2.6 Cross-site Scripting (XSS) vulnerability in Drupal core's sanitization API fails to properly filter cross-site scripting under certain circumstances. This issue affects: Drupal Core 9.1.x versions prior to 9.1.7; 9.0.x versions prior to 9.0.12; 8.9.x versions prior to 8.9.14; 7.x versions prior to 7.80.

Recommendation:

1. **Update and Patch:** Ensure that Drupal and all related modules and components are up to date with the latest security patches to mitigate known vulnerabilities.

2. **Input Validation:** Implement strong input validation and output encoding to sanitize user inputs and prevent the injection of malicious scripts.

3. **Content Security Policy (CSP):** Implement CSP headers to restrict the sources from which content can be loaded, reducing the risk of XSS.

4. **Secure Coding Practices:** Train developers in secure coding practices, emphasizing the importance of validating and escaping user inputs.

5. **Security Scanning:** Conduct regular security scans and penetration tests to identify and address XSS vulnerabilities.

8) Vulnerability Name: Denial of Service

CWE -400: Uncontrolled Resource Consumption

OWASP Category:

Description: The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if programming vulnerability is exploited, or the way the service handles resources it uses.

Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack to access critical information or execute commands on the server. Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 80 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ sudo su
[sudo] password for paavan:
┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap --top-ports 65536 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
zsh: segmentation fault  sudo nmap --top-ports 65536 31.3.96.40

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap -sV -p 80 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
Nmap scan report for web.mmebvba.com (31.3.96.40)
Host is up (0.043s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# msfconsole
```

```
Metasploit tip: Open an interactive Ruby terminal with
irb
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 31.3.96.40
RHOST => 31.3.96.40
msf6 auxiliary(dos/tcp/synflood) > set RPORT 80
RPORT => 80
msf6 auxiliary(dos/tcp/synflood) > RUN
[-] Unknown command: RUN
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 31.3.96.40

[*] SYN flooding 31.3.96.40:80 ...
```

Recommendation: Employ a robust Web Application Firewall (WAF) capable of filtering and mitigating suspicious traffic targeting port 80. Configure it to block excessive requests or patterns indicative of an attack. Utilize load balancing techniques to distribute traffic across multiple servers, ensuring no single server becomes overwhelmed. Additionally, implement rate limiting and throttling mechanisms to restrict the number of requests a single IP address can make within a defined time frame. Regularly monitor traffic patterns and set up alerts to detect unusual spikes in activity, enabling rapid response to potential attacks. Finally, keep software and systems up to date with the latest security patches to address known vulnerabilities that attackers may exploit.

9) Vulnerability Name: TLS Version 1.0 Protocol Detection

CWE-327: Use of a Broken or Risky Cryptographic Algorithm

OWASP Category: A02:2021-Cryptographic Failures

Description: The product uses a broken or risky cryptographic algorithm or protocol.

Business Impact: TLS 1.0 is an outdated and vulnerable encryption protocol, and its use can expose sensitive data to potential security threats. This not only jeopardizes the integrity of customer information and payment details but also tarnishes the company's reputation. The business may face legal consequences, loss of customer trust, and decreased revenue as security-conscious users avoid the site due to its security vulnerability. Immediate action is necessary to upgrade to a more secure TLS version to safeguard data, ensure compliance, and maintain customer confidence.

Steps to Reproduce:

1. Open a terminal or command prompt
2. Type the Command: openssl s_client -connect 31.3.96.40:443 -tls1
3. The connection is successfully means the server supports TLS 1.0

thanmaye08@THANMAYE: ~

File Actions Edit View Help

```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ openssl s_client -connect 31.3.96.40:443 -tls1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = web.mmebvba.com
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = web.mmebvba.com
verify return:1
---
Certificate chain
 0 s:CN = web.mmebvba.com
   i:CN = web.mmebvba.com
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: May 25 09:07:54 2015 GMT; NotAfter: May 22 09:07:54 2025 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIICxDCCAaygAwIBAgIJALpeeeDC90PLMA0GCSqGSIb3DQEBCwUAMBoxGDAWBgNV
BAMMD3dlYi5tbWVidmJhLmNvbTAeFw0xNTA1MjUwOTA3NTRaFw0yNTA1MjIwOTA3
NTRaMBoxGDAWBgNVBAMMD3dlYi5tbWVidmJhLmNvbTCCASIwDQYJKoZIhvcNAQEB
BQADggEPADCCAQoCggEBAK/hFlEmVRyv2fbXel6oUukbiGdpX0Xps5sqis2OxF9Y
/YXJcxaPoI/fUyfSdJ6prr2/YoEcUUfZaUIJWbsSz/qzklja0M+GMAVzL+wqAi+V
HjgujqsgeEQgxgTiNoQu9Zld5NY7Ac9qQRKbLBLRubQV/9+Dud0Isx3z1gAsJda6
bi3JuL0a27EMztRssKeQClJhWLAdidjuXH6kc+3jbNPmvedRF+Mw5mk32nNtyZ78
qjIFT7Bny/CNGN31PFgQWq+6pTgCzokui04zV0pYyaGX9hs6roLiQWLT9UqB0wx0
Jr+GM175u2YLvXba+UZ2cWMOp5IZ359OHtkf0uuKSzUCAwEAAaMNMAswCQYDVR0T
BAIwADANBgkqhkiG9w0BAQsFAAOCAQEAgKAHg1qFsUlDarYKIrjuUxfeI2bE1fLd
VGIYBzmaQddzehzBu9Akn9g73DHwrs9+gW9cDfkClVr3ayzS5KAMhvnZzga1B0+q
NYfX2y61SMnS4w9p8PT3iqZdF/RYwu658BXjpJWojwoA8Hu1mhwT0DdSSEofBnIq
azNm62lQsxdTlU7wEanZ0/ExUFNktwKean7Jle3EvH94fkNg2T0er1WuEB/QF6sv
dJqxsYSZ3toPEuqlOryWis0E8pfo3Hauzz6fBGijLcEnMoFp7oCZNz0Xh9Q93aOs
5c9hNmHtQcu3vMrYUYArpj+a/euAEI2HaGJZf5g75mf4gAI/2B7iyg==
-----END CERTIFICATE-----
subject=CN = web.mmebvba.com
issuer=CN = web.mmebvba.com
---
No client certificate CA names sent
Peer signing digest: MD5-SHA1
Peer signature type: RSA
Server Temp Key: ECDH, prime256v1, 256 bits
---
SSL handshake has read 1404 bytes and written 274 bytes
Verification error: self-signed certificate
---
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA
Server public key is 2048 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
```

```
No ALPN negotiated
SSL-Session:
    Protocol  : TLSv1
    Cipher    : ECDHE-RSA-AES256-SHA
    Session-ID: 88C081DC5A60B2165E5ECF1174DFFA77732428624861E0BFAC934E3DE969B9E2
    Session-ID-ctx:
    Master-Key: 9A895BD34544E92181A631AB636C46EEC2788E9BFEE0DA5A6BDCA50E65C55250BA88EA
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
    0000 - 11 e0 e2 5c 44 79 52 91-7b 32 b1 10 22 9f 80 b5    ...\DyR.{2..".. ..
    0010 - 54 b6 b7 89 fe c7 7d 4a-18 bd 8c e3 e6 31 47 63   T.....}J.....1Gc
    0020 - 38 1b 52 ec 16 ac 18 b6-bd e1 76 e9 4b 41 24 ad   8.R.......v.KA$.
    0030 - e3 94 d2 60 65 35 8b e0-6e d2 76 db 1b e1 03 e7    ...`e5..n.v.....
    0040 - e7 76 cc f9 70 6a 42 91-94 42 e2 e8 29 d5 fd 38   .v..pjB..B..)..8
    0050 - 63 5f da 9f 09 af e0 d9-22 29 45 70 a7 a4 36 1f   c_......")Ep..6.
    0060 - 51 b1 cd d5 e7 b9 ef 9d-5d 20 99 ad 00 4d 21 df   Q.......] ...M!.
    0070 - 38 a6 c9 1b 76 29 87 d9-14 79 7a 73 33 f8 4c 8f   8...v)...yzs3.L.
    0080 - 12 ae 66 c1 ad c3 6c ba-68 63 11 6c b2 18 e0 89   ..f...l.hc.l....
    0090 - 97 54 50 d7 ee f5 e1 37-f4 b0 be 55 2f d1 25 63   .TP....7...U/.%c
    00a0 - c7 61 10 b3 ad 74 5a b7-07 fe e5 20 b1 da a1 a2   .a...tZ.... ....
    00b0 - be dd c8 45 a7 74 b7 eb-ee 9a 15 dc 1b bb 0b d9    ...E.t..........

    Start Time: 1697691531
    Timeout   : 7200 (sec)
    Verify return code: 18 (self-signed certificate)
    Extended master secret: no
---
4037A3514B7F0000:error:0A000126:SSL routines:ssl3_read_n:unexpected eof while reading:
```

Recommendation:

1. **Upgrade to a Secure TLS Version:** Transition to a more secure TLS version, such as TLS 1.2 or TLS 1.3. This will provide stronger encryption and improved security against modern threats.

2. **Regularly Update SSL/TLS Configuration:** Keep your SSL/TLS configuration up to date to ensure it aligns with the latest security best practices and vulnerabilities.

3. **Implement a Strong Cryptographic Suite:** Use strong cipher suites and secure configurations to further enhance security. Disable weak ciphers and outdated protocols.

4. **Compliance Checks:** Ensure that your website complies with relevant data protection regulations and industry standards (e.g., GDPR, PCI DSS) to avoid legal issues.

10) Vulnerability Name: web.config File Information Disclosure

CWE-497: Exposure of Sensitive System Information to an Unauthorized Control Sphere

OWASP Category: A3:2017-Sensitive Data Exposure

Description: An information disclosure vulnerability exists in the remote web server due to the disclosure of the web.config file. An unauthenticated, remote attacker can exploit this, via a simple GET request, to disclose potentially sensitive configuration information.

Business Impact: It exposes sensitive configuration details, including database connection strings and encryption keys, to potential attackers. This could lead to unauthorized access, data breaches, and system compromise. The impact includes financial losses, damage to reputation, and legal liabilities as the organization's security and customer trust are compromised.

Steps to Reproduce:

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*



This produced the following truncated output (limited to 5 lines) :
------------------------------ snip ------------------------------
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Recommendation:

- Implement proper access controls to restrict access to the web.config file.
- Prevent directory traversal and ensure the web.config file cannot be directly accessed through the web server.
- Encrypt sensitive data within the configuration file.
- Regularly review and update the web.config file, removing any unnecessary sensitive information.
- Ensure that the web.config file is properly secured and not accessible to unauthorized users.

Main Website: vtop.vit.ac.in

1) **Vulnerability Name:** **SL Medium Strength Cipher Suites Supported (SWEET32)**

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

OWASP Category: Broken access control

Description: The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Business Impact: The vulnerability known as SWEET32 (Short for Sweet 32 Birthday Attack) relates to the continued use of legacy cryptographic cipher suites with 64-bit block sizes in TLS and SSL protocols. These suites are susceptible to birthday attacks, which exploit the probability of two blocks colliding after a certain number of transactions. If an organization's systems are vulnerable to SWEET32, it means they're potentially at risk of having encrypted communications intercepted or manipulated. This could lead to unauthorized access, data theft, or even the injection of malicious code. As a result, businesses face a significant risk to the confidentiality and integrity of their sensitive information. Remediation involves updating systems to support more secure cipher suites with larger block sizes, which would effectively mitigate this vulnerability and enhance the overall security posture. Failure to address SWEET32 could leave an organization exposed to increasingly sophisticated attacks and legal consequences due to potential data breaches.

Vulnerability Path: The Sweet32 vulnerability when detected with a vulnerability scanner will report it as a CVSS 7.5.

Steps to Reproduce:

HIGH SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also

https://www.openssl.org/blog/blog/2016/08/24/sweet32/
https://sweet32.info

Output

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

  Name                      Code            KEX          Auth     Encryption            MAC
  ----------------------    ----------      ---          ----     ---------------------  ---
  EDH-RSA-DES-CBC3-SHA      0x00, 0x16      DH           RSA      3DES-CBC(168)         SHA1
  ECDHE-RSA-DES-CBC3-SHA    0x C0, 0x12     ECDH         RSA      3DES-CBC(168)         SHA1
  DES-CBC3-SHA              0x00, 0x0A      RSA          RSA      3DES-CBC(168)         SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	136.233.9.22

Plugin Details

Severity:	High
ID:	42873
Version:	1.21
Type:	remote
Family:	General
Published:	November 23, 2009
Modified:	February 3, 2021

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +
Product Coverage: High
CVSSV3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.1
Risk Factor: Medium
CVSS v3.0 Base Score 7.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CVSS v2.0 Base Score: 5.0
CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: August 24, 2016

Recommendation: organizations should take several proactive steps. Firstly, it is crucial to update and configure cryptographic libraries, web servers, and any network devices to disable support for cipher suites with 64-bit block sizes. This can be achieved by ensuring that only modern and secure cipher suites are enabled in the TLS/SSL configurations. Additionally, organizations should regularly monitor and assess their systems for any outdated or vulnerable protocols and promptly apply security patches and updates. Implementing strong, unique encryption keys and employing forward secrecy protocols can further bolster security. It's also recommended to utilize intrusion detection systems and perform regular security audits to identify and address any potential vulnerabilities promptly. Lastly, organizations should stay informed about emerging security threats and best practices in cryptographic protocols to proactively adapt their security measures. By taking these measures, businesses can significantly reduce the risk of falling victim to SWEET32 attacks and enhance the overall security of their digital infrastructure.

2) **Vulnerability Name:** **Cookie SERVERID created without secure flag**

CWE-79: Improper Neutralization of Input During Web Page Generation

OWASP Category: A07-2017: Cross-site Scripting

Description: The vulnerability allows an attacker to inject malicious code into a WordPress website, which can then be executed by visitors to the website.

To exploit this vulnerability, an attacker would simply need to trick a user into clicking on a malicious link or opening a malicious attachment. Once the user clicks on the link or opens the attachment, the attacker's code would be executed, giving the attacker control over the user's account and potentially the entire WordPress website.

Business Impact: The business consequences of XSS can be severe, ranging from reputational damage due to compromised customer trust, to legal repercussions in cases of data breaches. Moreover, it can lead to financial losses through fraud or the cost of remediation efforts. Beyond the immediate impacts, long-term harm may occur if customers abandon the platform due to security concerns. To mitigate CWE-79, businesses must implement rigorous input validation and output encoding practices, as well as stay vigilant for emerging threats in web application security. Failure to address XSS vulnerabilities could result in significant harm to both the business's reputation and its bottom line.

Vulnerability Path: https://securityheaders.com/

q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

1. **Update and Patch:** Ensure that Drupal and all related modules and components are up to date with the latest security patches to mitigate known vulnerabilities.
2. **Input Validation:** Implement strong input validation and output encoding to sanitize user inputs and prevent the injection of malicious scripts.
3. **Content Security Policy (CSP):** Implement CSP headers to restrict the sources from which content can be loaded, reducing the risk of XSS.
4. **Secure Coding Practices:** Train developers in secure coding practices, emphasizing the importance of validating and escaping user inputs.
5. **Security Scanning:** Conduct regular security scans and penetration tests to identify and address XSS vulnerabilities.

3) **Vulnerability Name: X-Content-Type Options Header Missing**

CWE-918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The absence of the "X-Content-Type-Options" header poses a notable security risk for web applications. This header is a crucial security feature that instructs the browser to interpret files with a MIME type as declared in the Content-Type header, rather than trying to guess the type. When this header is missing, the browser may attempt to infer the content type, leaving room for potential misinterpretation and security vulnerabilities like MIME-sniffing attacks. This could enable attackers to disguise malicious content, such as scripts or executable files, as benign content, leading to Cross-Site Scripting (XSS) or other types of attacks. Implementing the "X-Content-Type-Options" header with the value "nosniff" is a fundamental security measure that helps prevent these risks. It ensures that browsers strictly adhere to the declared content type, enhancing the overall security posture of the web application and safeguarding against potential exploitation stemming from content misinterpretation.

Business Impact: The header missing impact Data Exposure(Attackers might force the server to render sensitive data as HTML, leading to data exposure),Security Risks(Content type manipulation can increase security risks, potentially leading to breaches, data leaks, and unauthorized access), Brand and Reputation Damage(Successful attacks that exploit SSRF vulnerabilities can harm the organization's reputation and trustworthiness)

Vulnerability Path:

https://securityheaders.com/?q=http%3A%2F%2Fvtop.vit.ac.in%2F&followRedirects=on

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "nosniff" in your web server or application to prevent content type sniffing.
- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.
- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

4) Vulnerability Name: Denial of Service

CWE - 400: Uncontrolled Resource Consumption

Description: The Denial of Service (DoS) attack is focused on making a resource (site, application, server) unavailable for the purpose it was designed. There are many ways to make a service unavailable for legitimate users by manipulating network packets, programming, logical, or resources handling vulnerabilities, among others. If a service receives a very large number of requests, it may cease to be available to legitimate users. In the same way, a service may stop if programming vulnerability is exploited, or the way the service handles resources it uses.

Sometimes the attacker can inject and execute arbitrary code while performing a DoS attack to access critical information or execute commands on the server. Denial-of-service attacks significantly degrade the service quality experienced by legitimate users. These attacks introduce large response delays, excessive losses, and service interruptions, resulting in direct impact on availability.

Business Impact: If successfully exploited, it involves overwhelming a system or application with excessive demands on its resources. This can lead to a range of disruptive consequences. The targeted system may experience significant slowdowns, or even complete unresponsiveness, making it difficult or impossible for legitimate users to access. Critical resources like CPU, memory, and network bandwidth can become depleted, causing further degradation in performance. In severe cases, the exploited vulnerability may lead to system crashes or failures, potentially resulting in data loss. This disruption not only impacts business productivity and financial stability but also risks reputational damage, eroding customer trust and confidence. Additionally, organizations may face regulatory compliance issues if the uncontrolled resource consumption leads to violations of service level agreements or industry standards. Mitigating this vulnerability requires proactive resource management practices and a well-prepared incident response plan to minimize the potential impacts on business operations and customer satisfaction.

Steps to Reproduce: exploit open ports 443 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 18:27 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.044s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1 c
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Linux 5.1 (87%), Apple macOS 10.13 (High Sierra
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.27 seconds
```

```
┌──(root㉿kali)-[/home/paavan]
└─# msfconsole

       =[ metasploit v6.3.27-dev                          ]
+ -- --=[ 2335 exploits - 1220 auxiliary - 413 post       ]
+ -- --=[ 1385 payloads - 46 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit tip: Adapter names can be used for IP params
set LHOST eth0
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 136.233.9.22
RHOST => 136.233.9.22
msf6 auxiliary(dos/tcp/synflood) > set RPORT 443
RPORT => 443
msf6 auxiliary(dos/tcp/synflood) > exploit
[*] Running module against 136.233.9.22

[*] SYN flooding 136.233.9.22:443...
^C[-] Stopping running against current target...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(dos/tcp/synflood) >
```

Recommendation: employ a robust Web Application Firewall (WAF) capable of filtering and mitigating suspicious traffic targeting port 80. Configure it to block excessive requests or patterns indicative of an attack. Utilize load balancing techniques to distribute traffic across multiple servers, ensuring no single server becomes overwhelmed. Additionally, implement rate limiting and throttling mechanisms to restrict the number of requests a single IP address can make within a defined time frame. Regularly monitor traffic patterns and set up alerts to detect unusual spikes in activity, enabling rapid response to potential attacks. Finally, keep software and systems up to date with the latest security patches to address known vulnerabilities that attackers may exploit.

5) Vulnerability Name: OS Identification

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

OWASP Category: A02:2021-Cryptographic Failures

Description: Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Business Impact: If sensitive information is improperly handled or inadequately protected, it can lead to financial losses, regulatory penalties, and damage to reputation. Customers may lose trust in the organization's ability to safeguard their data, potentially resulting in a loss of business and market share. Legal consequences and compliance issues may arise, leading to additional costs. Moreover, intellectual property theft or exposure can compromise a company's competitive edge. Remediation efforts, including implementing stronger security measures and compensating affected parties, can also entail substantial expenses. Overall, CWE-200 highlights the critical importance of robust data protection measures to safeguard an organization's financial health, reputation, and long-term viability.

Steps to Reproduce: use nmap -O TARGET to enable os detection

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 19:13 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.043s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:apple:mac_os_x:10.13 cpe:/o:linux:linux_kernel:5.1
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Apple macOS 10.13 (High Sierra) (Darwin 17.0.0) (86%), Linux 5.1 (86%), Linux 3.2 - 4.9 (86%), Linux 3.18 (
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
```

Recommendation: implementing robust encryption protocols for data both in transit and at rest, coupled with stringent access controls and strong authentication measures. Regular vulnerability assessments and penetration testing should be conducted to identify and rectify potential weak points. Educating employees through comprehensive security awareness training is vital, emphasizing proper data handling practices and recognition of potential threats. Employing data masking techniques for non-production environments and utilizing advanced Data Loss Prevention (DLP) solutions can further fortify defenses. Additionally, maintaining compliance with relevant data protection laws and regulations, as well as establishing a well-defined incident response plan, are crucial components of a comprehensive strategy to safeguard against sensitive information exposure.

This is stage 1 in the context of web application testing
and security we take help from

OWASP top 10 to understand them. The OWASP Top 10 is a widely recognized list of the most critical web application security risks. Understanding these risks is essential for ensuring the security of web applications.

Stage 2

Overview

Nessus is a widely recognized vulnerability scanning tool developed by Tenable, Inc., used to identify security weaknesses in computer systems, networks, and web applications. It functions as a remote vulnerability scanner, meaning it does not require installation on the target machine. Instead, it communicates remotely with the target system by sending various probes and requests to detect security flaws and configuration issues.

During the scanning process, Nessus analyzes the target environment by generating network traffic, issuing operating system queries, and sending application-level requests. These probes help the scanner collect information regarding system configurations, running services, open ports, and possible vulnerabilities.

A key capability of Nessus is its plugin-based architecture. Plugins are specialized scripts designed to detect specific vulnerabilities in systems, applications, or network devices. Nessus maintains a large and regularly updated repository containing thousands of such plugins, allowing it to identify newly discovered security issues. Each plugin conducts a particular test, such as identifying outdated software versions, weak encryption mechanisms, configuration errors, or publicly known vulnerabilities.

When a Nessus scan begins, the first step is host discovery. During this phase, discovery plugins determine information about the target system, including the operating system, active services, and running applications. After gathering this information, Nessus executes additional vulnerability detection plugins against the identified services.

Once the scanning process is complete, Nessus generates a detailed vulnerability report. This report includes information such as vulnerability severity levels, technical explanations, reproduction procedures, and recommended remediation steps. Security professionals use these reports to assess risk levels and prioritize necessary fixes.

Nessus can scan a variety of targets, including individual machines, entire networks, or web applications. It also supports scanning of specific ports, protocols, or services depending on the organization’s security requirements. Additionally, the platform supports both manual and scheduled scans, enabling organizations to perform continuous vulnerability assessments efficiently.

How Nessus Works (Step-by-Step)

The vulnerability scanning process carried out by Nessus generally follows these steps:

1. **Connection to the Target System**
   Nessus establishes communication with the target host using network protocols such as TCP, UDP, and ICMP.

2. **System Discovery**
   The scanner gathers information about the operating system, running services, and open ports on the target machine.

3. **Vulnerability Testing**
   Nessus executes multiple security plugins that test the identified services for known vulnerabilities and weaknesses.
4. **Report Generation**
   After completing the scan, Nessus produces a detailed report that lists detected vulnerabilities, their severity levels, and recommended solutions.

Benefits of Using Nessus
Nessus offers several advantages that make it one of the most widely used vulnerability scanners in cybersecurity:
Comprehensive Vulnerability Detection
Nessus includes a large collection of plugins that allow it to detect a wide range of vulnerabilities across operating systems, applications, and network devices.
User-Friendly Interface
The tool provides an intuitive interface that simplifies the configuration and execution of vulnerability scans.
Detailed Security Reports
Nessus generates structured reports that include vulnerability severity, technical descriptions, reproduction steps, and recommended solutions.
Scalability
The scanner can analyze individual systems, multiple servers, or entire network infrastructures.
Flexible Scanning Options
Nessus allows users to run scans manually or schedule automated scans for regular vulnerability assessments.

Target Website: http://testfire.net/
Target IP Address:65.61.137.117

List of Vulnerabilities

S.NO	Vulnerability Name	Severity	Plugin
1	TLS Version 1.0 Protocol Detection	Medium	104743
2	TLS Version 1.1 Protocol Deprecated	Medium	157288
3	SSL/TLS Diffie-Hellman Modulus ≤1024 Bits (Logjam)	Low	83875
4	ICMP Timestamp Request Remote Date Disclosure	Info	10114
5	Additional DNS Hostnames	Info	46180

S.NO	Vulnerability Name	Severity	Plugin
6	Apache Tomcat Detection	Info	39446
7	Common Platform Enumeration (CPE)	Info	45590
8	Device Type	Info	54615
9	HSTS Missing from HTTPS Server	Info	84502
10	HTTP Server Type and Version	Info	10107

REPORT

1.Vulnerability Name: TLS Version 1.0 Protocol Detection

Severity: Medium

Plugin: 104743

Port: 443

Description:

The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 contains several cryptographic design weaknesses that make it insecure for modern communication. Many modern browsers and security standards no longer support TLS 1.0 due to these vulnerabilities.

Solution:

Disable TLS 1.0 and configure the server to support only secure protocols such as TLS 1.2 or TLS 1.3.

Business Impact:

Using outdated encryption protocols can allow attackers to intercept sensitive communication, leading to potential data breaches and loss of confidentiality.

2.Vulnerability Name: TLS Version 1.1 Protocol Deprecated

Severity: Medium

Plugin: 157288

Port: 443

Description:

The server supports TLS 1.1 which is considered outdated and insecure. It lacks support for modern cipher suites and stronger encryption mechanisms.

Solution:

Disable TLS 1.1 and upgrade the server configuration to support TLS 1.2 or TLS 1.3.

Business Impact:

Attackers may exploit weaknesses in outdated protocols to intercept or manipulate encrypted data.

3.Vulnerability Name: SSL/TLS Diffie-Hellman Modulus ≤1024 Bits (Logjam)
Severity: Low
Plugin: 83875
Port: 443
Description:
The server supports weak Diffie-Hellman encryption parameters which are vulnerable to the Logjam attack. Weak key sizes reduce the strength of encrypted communication.
Solution:
Configure the server to use stronger Diffie-Hellman parameters of 2048 bits or greater.
Business Impact:
Weak encryption may allow attackers to decrypt sensitive communications or compromise data integrity.

4.Vulnerability Name: ICMP Timestamp Request Remote Date Disclosure
Severity: Info
Plugin: 10114
Port: 0
Description:
The remote system responds to ICMP timestamp requests, revealing the system's date and time to external users.
Solution:
Block ICMP timestamp requests and replies through firewall configuration.
Business Impact:
Attackers can use this information for reconnaissance and planning further attacks.

5.Vulnerability Name: Additional DNS Hostnames
Severity: Info
Plugin: 46180
Port: 0
Description:
The scanner identified additional DNS hostnames that point to the same server.
Solution:
Review DNS configuration and verify that all hostnames are legitimate and properly secured.
Business Impact:
Information disclosure about server infrastructure can help attackers understand system architecture.

6.Vulnerability Name: Apache Tomcat Detection
Severity: Info
Plugin: 39446
Port: 80
Description:
The scan detected that the server is running Apache Tomcat web server software.
Solution:
Ensure the Tomcat server is updated with the latest security patches and properly configured.
Business Impact:
If the Tomcat version is outdated, attackers may exploit known vulnerabilities in that software.

7.Vulnerability Name: Common Platform Enumeration (CPE)
Severity: Info
Plugin: 45590
Port: 0
Description:
The scan identified software and hardware products on the server using CPE identifiers.
Solution:
Use this information for asset management and ensure all detected software is regularly updated.
Business Impact:
Although informational, attackers may use this information to identify potential vulnerabilities.

8.Vulnerability Name: Device Type
Severity: Info
Plugin: 54615
Port: 0
Description:
The scanner identified the device type based on the operating system fingerprint.
Solution:
Ensure that proper security controls are implemented for the detected device.
Business Impact:
Attackers may use this information to design targeted attacks against the system.

9.Vulnerability Name: HSTS Missing from HTTPS Server
Severity: Info
Plugin: 84502
Port: 443
Description:
The server does not enforce HTTP Strict Transport Security (HSTS), which ensures secure HTTPS communication.
Solution:
Enable HSTS in the web server configuration to force browsers to use HTTPS connections.
Business Impact:
Without HSTS, attackers may perform SSL-stripping attacks or downgrade attacks.

10.Vulnerability Name: HTTP Server Type and Version
Severity: Info
Plugin: 10107
Port: 443
Description:
The scanner detected the type and version of the web server running on the system.
Solution:
Hide server version details and keep the web server software updated with the latest security patches.
Business Impact:
Attackers may use server version information to find known vulnerabilities and exploit them.

Stage 3
Report

Title: - Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

Zero Trust Network Access (ZTNA)
Introduction

Zero Trust Network Access (ZTNA) is a cybersecurity framework designed to provide secure remote access to internal organizational applications and data by enforcing strict access control policies.

In contrast to traditional Virtual Private Networks (VPNs) that often grant users broad access to an entire network, ZTNA follows the principle of "never trust, always verify." Users are allowed access only to the specific applications they require, and only after their identity and device security status have been validated.

ZTNA forms an essential part of modern security architecture because it removes the reliance on the conventional concept of a trusted internal network and an untrusted external environment—commonly known as the castle-and-moat model.

By concealing internal systems from the internet and establishing encrypted one-to-one connections between users and applications, ZTNA significantly reduces the available attack surface and prevents threats such as lateral movement by attackers.

The ZTNA Access Cycle

The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policies for every access request.

Steps in the ZTNA Cycle

1. **User Request**
   A user from any location (office, home, coffee shop) requests access to a specific internal application such as an HR portal, finance server, or internal code repository.

2. **Identity and Device Verification**
   Before establishing any connection, the ZTNA solution verifies:
   - User identity using **Multi-Factor Authentication (MFA)**
   - Device security posture

   The device is checked for:
   - Updated antivirus
   - Firewall health
   - Absence of compromise or malware
3. **Policy Enforcement**
   The ZTNA system evaluates the access policy:
   - Does the user have permission?
   - Is the device compliant?
   - Is the access request valid for the time and context?
4. **Establish Secure Connection**
   If the policy allows access, a **secure encrypted micro-tunnel** is created between the user device and the application.
   Importantly, the user **never gains access to the internal network**, only the specific application.
5. **Continuous Monitoring**
   The system monitors the session continuously.
   If suspicious behaviour or device compromise is detected, the connection is **terminated immediately**.
6. **Logging and Analytics**
   All access attempts are logged and analysed for:
   - Security auditing
   - Threat detection
   - Policy improvements

Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a **cloud-native security platform** that delivers services entirely from the cloud, eliminating the need for on-premises hardware such as VPN concentrators.
For ZTNA, Zscaler provides **Zscaler Private Access (ZPA)**.
ZPA enables **identity-based secure access to private applications without placing users directly on the network.**
The concept is simple: The application resides **inside the Zscaler cloud**, and users connect securely through the cloud.

Zscaler Collects Data From

1. **Identity Providers (IdP)**
   Examples:
   - Azure AD
   - Okta
   - Ping Identity
2. **Device Posture Partners**
   - CrowdStrike
   - Tanium
   - Microsoft Defender for Endpoint
3. **Business Applications**
   - Internal web applications
   - File servers
   - Legacy applications in data centers or public cloud (AWS, Azure)
4. **Zscaler App Connectors**
   Lightweight software deployed in the data center that creates outbound connections to Zscaler cloud, making internal servers **invisible to the internet**.

Zscaler Policy Enforcement

Policies are enforced based on:

1. **Identity-Based Access**
2. **Application Segmentation**
3. **Least Privilege Access**

The Zscaler ZTNA Cycle

The **Zscaler ZTNA cycle** implements ZTNA principles using the Zscaler cloud platform.

Steps

1. **User Login and Authentication**
   - User attempts to access an internal application.
   - Redirected to the **Identity Provider (IdP)** for authentication and MFA.
2. **Device Posture Check**
   - Zscaler verifies device compliance with integrated security tools.
3. **Policy Evaluation**
   - Zscaler cloud evaluates the request based on:
     - User identity
     - Device posture
     - Context (time, location)
4. **Establish Micro-Tunnel**
   - Zscaler Client Connector and App Connector establish an encrypted connection.

5. **Traffic Inspection (Optional)**
    - Traffic can be inspected for:
        - Data Loss Prevention (DLP)
        - Malware detection
6. **Logging and Analytics**
    - All activities are recorded for:
        - Reporting
        - Threat hunting
        - Compliance

MISP (Malware Information Sharing Platform) Integration

Zscaler can be enhanced using **MISP**, a threat intelligence sharing platform.

Uses of MISP Integration

1. **Threat Intelligence Feed**
    - Provides information about malicious domains, IP addresses, and URLs.
2. **Proactive Blocking**
    - Zscaler Internet Access (ZIA) blocks malicious sites identified by MISP.
3. **Enhanced Visibility**
    - Security teams can cross-reference Zscaler logs with MISP threat intelligence.

College Network Infrastructure

The college network infrastructure includes:

- Core routers and switches.
- Distribution routers and switches
- Wireless access points
- Firewalls and Intrusion Detection Systems (IDS)
- Internal application servers:
    - Student information system
    - Library resources
    - Research repositories
    - Administrative portals

The network currently uses a **legacy VPN concentrator** for remote access.

Limitations of the Current VPN Model

1. **Over-Permissioned Access**
    - VPN users gain broad network access.
    - A compromised device could scan and attack the entire internal network.
2. **Limited External Collaboration**
    - External researchers require restricted application access without network exposure.

3. **Poor User Experience**
    - Legacy VPN systems can be slow and route all internet traffic through the university network.

Deployment of ZTNA Using Zscaler in the College

To deploy **Zscaler ZPA**, the college must transition from **network-based security to application-based access control.**

Deployment Plan

1. **Application Discovery**
    - Identify internal applications currently accessed via VPN.
2. **User Segmentation**

   Define user groups:
    - Students
    - Faculty (Research)
    - Faculty (Administration)
    - IT Staff
    - External Collaborators
3. **Deploy Zscaler App Connectors**
    - Install App Connector VMs in the data center.
    - These connectors create outbound connections to the Zscaler cloud.
4. **Integrate Identity Provider**
    - Connect Zscaler with existing identity systems such as **Azure AD**.
5. **Configure Access Policies**

   Example policy:

   "Faculty group can access ERP application from devices with antivirus enabled after MFA verification."
6. **Deploy Zscaler Client Connector**
    - Installed on laptops and mobile devices.
    - Routes private traffic through ZPA and internet traffic through ZIA.

Threat Intelligence

Threat intelligence enhances ZTNA by providing contextual security insights.

Sources

1. **Zscaler Cloud Logs**
2. **External Threat Feeds (MISP)**
3. **Identity Provider Logs**

Applications

1. **Adaptive Access Control**
2. **Compromised Account Detection**
3. **Blocking Malicious Communications**

Incident Response in a ZTNA Environment

Incident response becomes faster and more efficient with ZTNA.

Steps

1. **Detection**
   - SOC detects anomalies such as unusual data downloads.
2. **Containment**
   - User access can be instantly revoked via the Zscaler portal.
3. **Eradication**
   - The compromised device is cleaned and scanned.
4. **Recovery**
   - Access is restored after remediation.
5. **Post-Incident Review**
   - Logs are analysed to improve policies.

Benefits

1. Near-instant containment
2. No lateral movement
3. Detailed forensic data
4. Regulatory compliance

Understanding the Tool: Zscaler ZPA

Key characteristics of **Zscaler Private Access (ZPA)**:

1. **Application-Centric Security**
2. **Hidden Internal Network**
3. **Dark Cloud Architecture**
4. **Improved User Experience**
5. **High Scalability**

Conclusion

This project examined the importance of AI-driven security mechanisms and Zero Trust architecture within modern cybersecurity environments.

- During Stage 1, the focus was on web application testing and identifying potential security vulnerabilities.
- Stage 2 involved analyzing vulnerabilities through detailed Nessus scanning reports.
- In Stage 3, the project demonstrated the practical deployment of Zero Trust Network Access using Zscaler ZPA.
- ZTNA represents a transition from traditional network-centric security models to identity-based access control, ensuring that internal applications remain concealed from external threats while providing secure connectivity for legitimate users.

As cloud computing and remote work environments continue to expand, Zero Trust frameworks are expected to become fundamental elements of future cybersecurity strategies.

Future Scope

Future of Web Application Testing

Key trends include:

- Increased focus on security testing
- Use of AI and Machine Learning
- Cloud-based testing platforms
- Enhanced user experience testing

Future Scope of Software Testing

1. Continuous testing across the SDLC
2. AI-driven testing automation
3. Cloud-based testing environments
4. Increased test automation

Future Scope of SOC / SIEM

Future developments include:

1. **AI-Driven Zero Trust Architecture**
2. **Integration with Edge Computing and IoT**
3. **Identity-Centric Security Models**
4. **Integration with SASE Architecture**
5. **Zero Trust for Critical Infrastructure**
6. **Automated Threat Hunting and Response**

Topics Explored

- Data Collection and Aggregation
- Standardization and Normalization
- Enrichment and Analysis
- Threat Intelligence Sharing
- Security Tool Integration
- Automation and Orchestration
- Incident Response Support

SOC and SIEM Tools Explored

- Nmap
- Metasploit
- Nessus
- Kali Linux
- OWASP ZAP
- Burp Suite

THE END